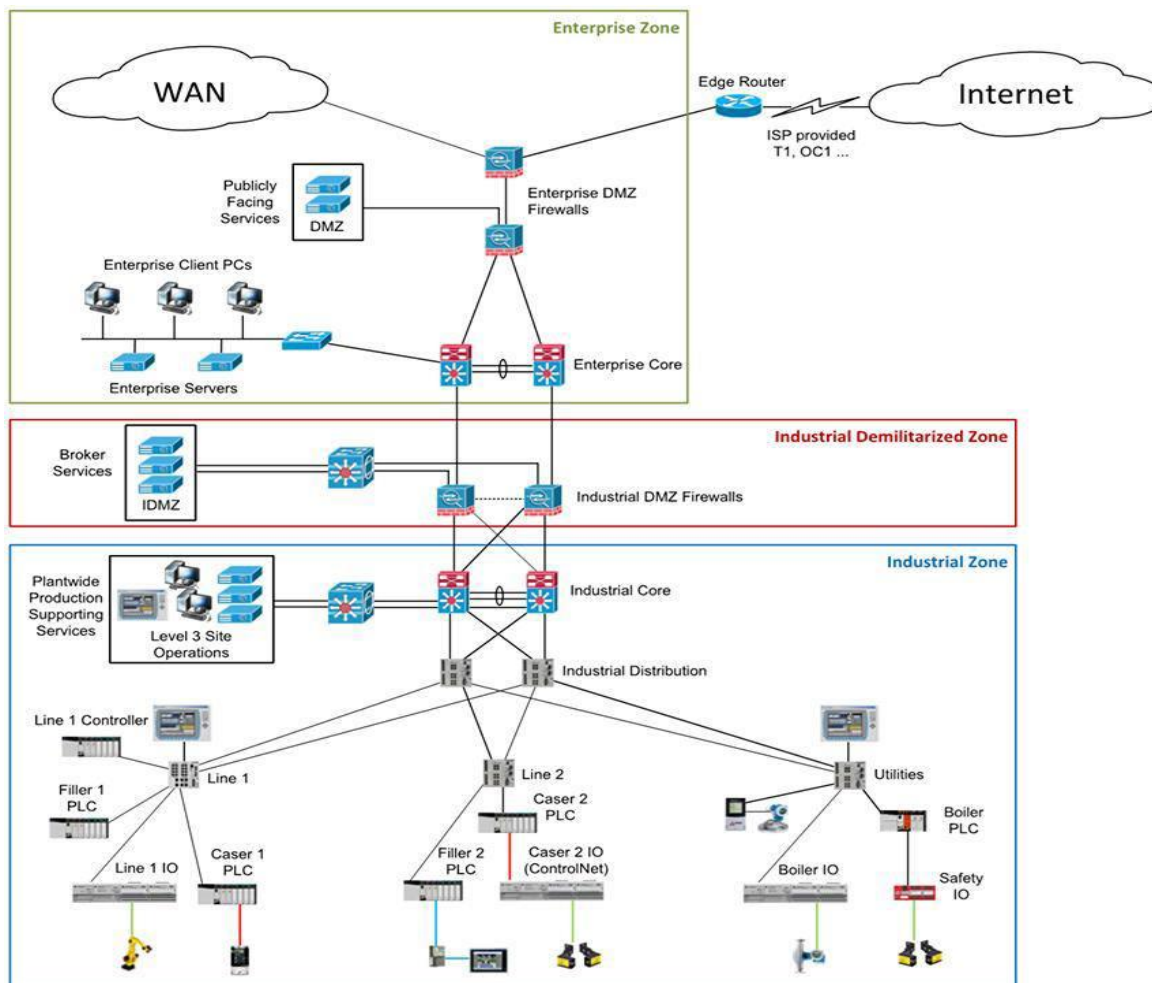


Выполнил: Four-Seasons

Модуль В: Защита ИТ-инфраструктуры

Схема задания:



Задание:

1. Определите потенциальные цели и назначение крупных сегментов сети
2. Опишите риски ИБ для каждого из крупных сегментов сети
3. Добавьте отсутствующие компоненты ИС
4. Добавьте компоненты архитектуры ИБ (идентификация, управление, контроль, анализ, мониторинг, автоматизация)

Каждый пункт пропишите под своим параметром.
Используйте формат ПДФ.

Описание Инфраструктуры

Перед выполнением задания систематизируем информацию по сети:

1. Global Zone:

Устройства: базовый ISP, который смотрит в Internet (и Edge Router)

2. Enterprise Zone (Предприятие):

1) Зона между первым и вторым Firewalls.

- Устройства: Межсетевые экраны (Enterprise DMZ Firewalls), публичные общедоступные сервисы (IDZ).
- Назначение: Буферная зона между интернетом и внутренней сетью предприятия для размещения публично доступных услуг.

2) Зона после второго межсетевого экрана

- Устройства: Клиентские (пользовательские) ПК, корпоративные серверы, WAN-маршрутизаторы (коммутаторы). Тип сети : присутствует формат «Общая шина».
- Назначение: Офисная IT-инфраструктура для бизнес-процессов (бухгалтерия, CRM, почта, документооборот).

3. Industrial Demilitarized Zone (IDMZ):

- Устройства: Межсетевые экраны (Firewalls), Broker Services формата IDMZ (сервисы-посредники).
- Назначение: Критически важный буфер между IT (Enterprise) и OT (Operational Technology - Industrial) сетями. Обеспечивает сегментацию и контролируемый обмен данными. В нем вроде, как и должна происходить фильтрация данных.

4. Industrial Zone (Производственная зона или же Operational Technology):

- Уровень 3 (Site Operations): Сервисы поддержки производства (источники данных, MES-системы). По устройствам два клиентских (пользовательских) ПК, три сервера.
- Линия 1: Контроллер линии (Line 1 Controller), ПЛК (Filler PLC, Caser PLC.), Линия 1 ввода-вывода (Line 1 IO).
- Линия 2: Модули ввода-вывода (IO), приводы, датчики, фильтры.
- Utilities: (Ввод-вывод, PLC, безопасность ввода-вывода) котла.
- Назначение: Непосредственное управление и мониторинг технологического оборудования на производстве.

1. Определите потенциальные цели и назначение крупных сегментов сети

Сегмент сети	Потенциальные цели для атакующего	Назначение сегмента
Enterprise Zone (1)	- Публичные сервисы для их компрометации и размещения вредоносного кода. - Получение точки опоры для атак вглубь сети (на Enterprise Zone 2). - Организация DDoS-атак на сервисы.	Размещение общедоступных услуг, информации, данных, доступных из интернета. Защита внутренней сети предприятия от прямого воздействия извне (Firewalls).
Enterprise Zone (2)	- Конфиденциальные данные (финансы, персональные данные, интеллектуальная собственность). - Учетные записи пользователей для дальнейшего перемещения по сети. - Вычислительные ресурсы для организации бот-сети или майнинга.	Обеспечение бизнес-процессов компании. Хранение и обработка корпоративной информации. Доступ сотрудников к приложениям и данным.
Industrial DMZ (IDMZ)	- Сервисы-посредники (Broker Services) для перехвата данных между Enterprise Zone и Industrial Zone. - Межсетевые экраны для их отключения или изменения правил. - Получение контроля над каналом связи между бизнес- и производственной сетями.	Изоляция производственной (ОТ) сети от корпоративной (ИТ). Контроль и фильтрация всего трафика между зонами. Предотвращение прямого доступа из интернета к внутренним системам.
Industrial Zone	- Системы управления технологическими процессами (ПЛК, контроллеры) для остановки производства или изменения его параметров. - Источники данных для промышленного шпионажа или фальсификации данных. - Устройства уровня 1 (ИО) для причинения физического ущерба оборудованию и персоналу. Тем самым вызвав приостановку рабочего процесса.	Непосредственное управление физическим производственным процессом. Возможно, что сбор телеметрии и данных с оборудования. Обеспечение безопасности, качества и эффективности выпуска продукции. Управление оборудованием.

2. Опишите риски ИБ для каждого из крупных сегментов сети

Сегмент сети	Ключевые риски информационной безопасности
Enterprise Zone (1)	1. Взлом веб-приложений: Использование уязвимостей (OWASP Top 10) для получения доступа. (Примеры: использование SQL-инъекций, вставок кода, файлов, поддерживаемых скрипты и т.д.) 2. Компрометация ОС: Несвоевременное обновление патчей на публичных серверах. 3. Некорректная настройка МСЭ: Излишне разрешающие правила, открывающие путь внутрь сети и доступ к данным, которые при ограничении были бы закрыты. Высокие привилегии доступа. 4. Устаревшее ПО: старые версии программ, утилит и т.д., которые давно не обновлялись.
Enterprise Zone (2)	1. Заражение вредоносным ПО: Фишинг, ransomware (шифровальщики) через почту или веб-браузеры. + Человеческий фактор. 2. Утечка данных: Внутренние нарушители или внешние атаки на серверы. 3. Несанкционированный доступ: Слабые пароли, отсутствие многофакторной аутентификации, несоблюдение принципа наименьших привилегий. 4. DDoS-атаки: На ключевые внутренние сервисы (файловые хранилища, системы управления). 5. Плоская сеть (общая шина): Свободное перемещение злоумышленника: Получение доступа к одному хосту дает возможность сканировать и атаковать все остальные системы в сегменте (клиентские ПК, серверы, системы управления). Возможно массовое заражение ransomware: Без изоляции между рабочими станциями и серверами вирус-шифровальщик может беспрепятственно распространиться на все критические ресурсы зоны. Возможность реализации повышения прав доступа и привелегий. (Возможно, т.к. используется формат сети общая шина)
Industrial DMZ (IDMZ)	1. Нарушение сегментации: Обход МСЭ через не подконтрольные каналы связи (например, модемы). 2. Компрометация Broker Services: Превращение их в дальнейший ресурс для атак на Industrial Zone и дальнейшего проникновения в нее Industrial Zone. 3. Отсутствие мониторинга трафика: Невозможность обнаружить аномальную активность или попытки сканирования между зонами.
Industrial Zone	1. Критические киберфизические атаки: Остановка конвейера, повреждение оборудования, создание опасных для жизни условий. (Стоит ли это только вопрос считать за риск ИБ, но кибер безопасность точно, т.к. воздействие на устройства происходит). 2. Использование уязвимостей в коде оборудования контроллеров и ПО АСУ ТП: Многие программируемые устройства, работающие на предприятиях имеют старые версии ПО и защиты (К примеру промышленные протоколы СIP, Modbus не имеют встроенной аутентификации или шифрования, потому мы легко можем перехватить контроль над устройствами с данными протоколами, если попадем в сеть). 3. Распространение вредоносного ПО: Через съемные носители (USB) или из корпоративной сети, что может привести к заражению всего производственного контура (например, вирусами типа Triton, Industroyer). Тогда злоумышленник может попытаться пойти снизу в верх по сети. (От устройства рабочего на предприятии до полного доступа к всей инфраструктуре).

3. Добавьте отсутствующие компоненты ИС

Компонент	Назначение и место размещения	Обоснование и рекомендуемые источники для изучения
Система обнаружения и предотвращения вторжений (IDS/IPS) (Мониторинг трафика)	- Сетевые (NIDS): На границе сети (за МСЭ в Enterprise Zone 1) и в критически важных сегментах (перед Industrial Core). - Хосты (HIDS): На критических серверах в Enterprise Zone и на компьютерах инженеров в Industrial Zone (Уровень 3). IDS-обнаружение IPS-предотвращение	Обоснование: Для обнаружения и блокировки аномальной сетевой активности и атак на уровне хостов. Источники: - NIST SP 800-94: "Guide to Intrusion Detection and Prevention Systems (IDPS)". - CIS Controls v8: Control 12 (Network Infrastructure Management) и Control 13 (Network Monitoring and Defense).
Система управления событиями и информационной безопасностью	Централизованный сервер для сбора и корреляции логов со всех устройств (МСЭ, IDS, IPS, серверов, активного сетевого оборудования).	Обоснование: Обеспечивает единую картину безопасности, позволяет обнаруживать сложные многоэтапные атаки. Источники: - Модель зрелости SANS для SIEM. - Использование MITRE ATT&CK Framework для построения правил корреляции.
Система резервного копирования и восстановления	Автономные и защищенные хранилища для критических систем (серверы БД, конфигурации ПЛК). Резервные копии должны быть изолированы от основной сети.	Обоснование: Критически важна для восстановления после инцидентов, включая атаки ransomware. Источники: NIST SP 800-34: "Contingency Planning Guide for Federal Information Systems". Как вариант: Стратегия 3-2-1 (3 копии, 2 носителя, 1 копия вне площадки).
Система микросетевой сегментации (Microsegmentation)	- Логическое разделение: Создание VLAN для изоляции групп пользователей (бухгалтерия, отдел кадров) и серверов по функциям (БД, файловые, управление). - Физическое размещение: Внутренний межсетевой экран или L3-коммутатор с ACL на уровне Enterprise Core. - Принудительное	Предотвращение перемещение "сосед-сосед" после первоначального взлома. Снижение "поверхности атаки" и сдерживание ransomware. Принудительное перемещение в точку контроля можно реализовать через NFTables + фильтрацию. Источники: NIST SP 800-207: "Zero Trust Architecture" - продвигает идею

	применение правил: Трафик между сегментами должен проходить через точку контроля.	сегментации на основе идентичности. • MITRE ATT&CK Mitigation M1030: "Network Segmentation" - прямая рекомендация против тактик латерального перемещения.
Система контроля привилегированного доступа (PAM)	Выделенный сервер для хранения, перемещения и контроля использования паролей администраторов, инженеров и системных учетных записей.	Обоснование: Защита от кражи и неправомерного использования учетных данных с максимальными правами. Источники: • Модель BeyondCorp от Google (как пример подхода "нулевого доверия"). • CyberArk Blueprint по внедрению PAM.

4. Добавьте компоненты архитектуры ИБ (идентификация, управление, контроль, анализ, мониторинг, автоматизация)

Компонент архитектуры ИБ	Конкретные меры и технологии для внедрения	Обоснование и ссылки на стандарты
Идентификация	1. Единая система аутентификации: Active Directory с политиками сложных паролей. 2. Многофакторная аутентификация (MFA): Обязательна для доступа к публичным сервисам, VPN, привилегированным учетным записям и системам в Industrial Zone (Уровень 3). 3. Сертификаты и PKI: Для аутентификации устройств (МСЭ, серверов) и защищенного обмена данными. Использование ключей, при удаленном подключении и отсутствие доступа дистанционно к важным ролям (к admin).	Обоснование: Основа контроля доступа. Без надежной аутентификации все остальные меры неэффективны. Источники: • NIST SP 800-63B: "Digital Identity Guidelines". • RFC 5280: Основа для PKI.
Управление	1. Политика сегментации: Четкие правила на МСЭ между всеми зонами. Запрет по умолчанию, разрешение только необходимых протоколов и портов. 2. Система управления конфигурациями: Централизованное управление настройками МСЭ, правилами IDS (системы обнаружения вторжений).	Обоснование: Сегментация (разделение сети)— ключевой метод сдерживания распространения атак, особенно между IT и OT. Источники: • ISA/IEC 62443-3-2: описание сегментации. • NIST SP 800-82: "Guide to Operational Technology (OT) Security".
Контроль	1. Принудительное применение правил: МСЭ в IDMZ и на границе. 2. Контроль съемных носителей: Запрет или строгий контроль использования USB-устройств в Industrial Zone. 3. EDR-системы: Контроль и изоляция зараженных рабочих станций, сервером и PC клиентов в реальном времени.	Обоснование: Претворение политик в жизнь. Активное противодействие угрозам. Источники: • CIS Critical Security Controls v8: Control 14 (Controlled Access). • NIST SP 800-53: Контроль SC-7 (Boundary Protection).
Анализ	1. SIEM-система: Анализ и поиск взаимосвязи событий. 2. Песочница (Sandboxing): Анализ подозрительных файлов. 3. Анализ уязвимостей: Регулярное сканирование IT-активов и пассивное сканирование OT-сети.	Обоснование: Предупреждающее выявление слабостей и признаков попыток атак (взлома). Еще интересный вариант. Создание песочницы (Запуск подозрительных файлов на виртуальных машинках с целью проверки его на угрозу Sandboxing).

		Касательно SIEM озвучивалось в прошлой задаче: система управления событиями и информацией безопасности. Главный центр безопасности. Источники: • NIST SP 800-115: "Technical Guide to Information Security Testing".
Мониторинг	1. Платформа для частично автоматизации реагирования на инциденты. (SOAR) 2. Мониторинг сетевого трафика в ОТ: Специализированные решения, "понимающие" промышленные протоколы. 3. Мониторинг целостности файлов: На критических серверах и рабочих станциях инженеров.	Обоснование: Непрерывный контроль для оперативного выявления и подавления инцидентов. Источники: • NIST SP 800-137: "Information Security Continuous Monitoring (ISCM)". • Концепция SOAR от Gartner.
Автоматизация	1. Автоматизация реагирования: Интеграция SIEM и SOAR для автоматического выполнения сценариев (блокировка IP, отключение порта и т.д.). 2. Автоматизированное создание отчетов. 3. Координация исправлений: Для IT-систем.	Обоснование: Снижение времени реагирования (MTTR), повышение устойчивости системы. Источники: • NIST SP 800-160 Vol. 2: О развитии киберустойчивых систем. • Рекомендации CISA по автоматизации блокировки IOCs.

Заключение

Нами была рассмотрена ИТ-Инфраструктура и выполнены следующие задачи:

1. Просмотрены как разделы ИТ-ИФ, так и отдельные части.
2. Определение потенциальной цели и назначения ее главных сегментов.
3. Описание рисков ИБ для каждого сегмента сети.
4. Добавлены отсутствующие компоненты ИС.
5. Добавлены компоненты архитектуры ИБ.